

CSE 331: System Security Fundamentals

Spring 2026

Authentication:
Passwords, MFA, and Biometrics

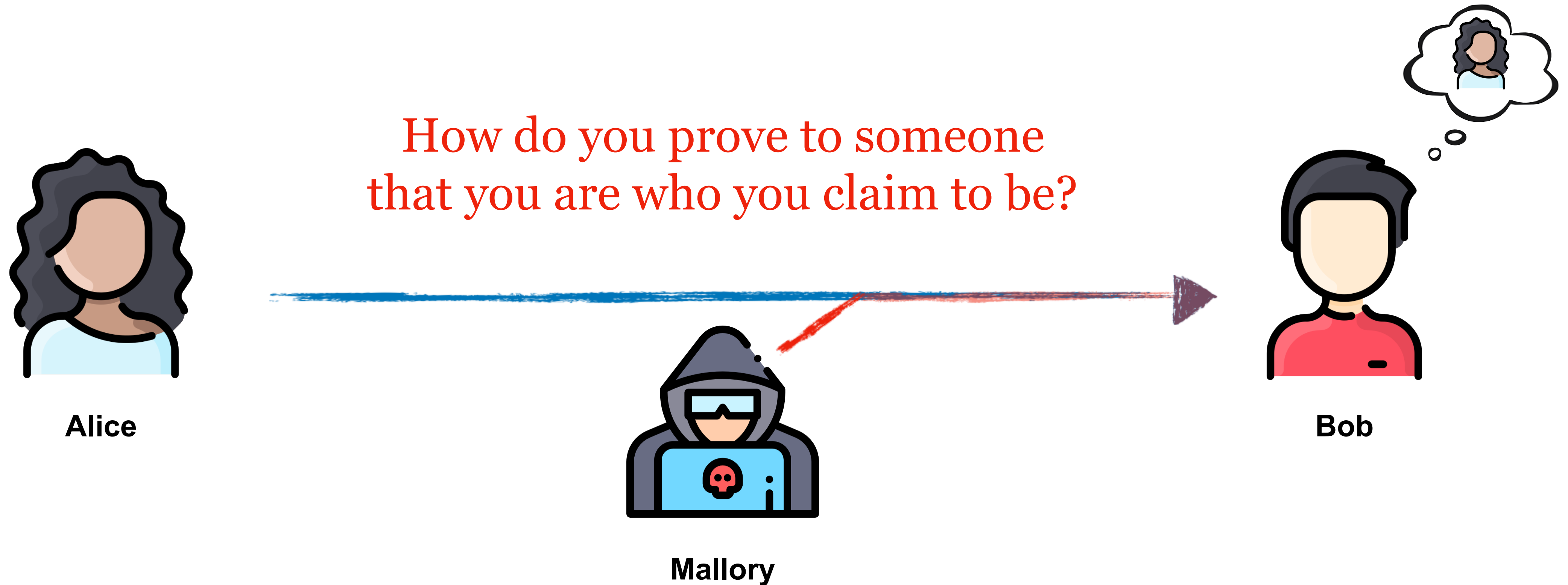
Amir Rahmati
Xinrui Yu



Stony Brook Institute
at Anhui University

安徽大学纽约石溪学院

Basic Problem



Any system with access control must solve this problem.

We examine the password approach today.

Passwords and Computer Security

- Most of network intrusions take advantage of weak authentication.
 - In 2012, 76% of network intrusions exploited weak or stolen credentials (username/password)
 - Source: Verizon Data Breach Investigations Report

How to Store a Password



User	Password
alice	password123
bob	qwerty123
...	...



User	Password
alice	Hash(password123)
bob	Hash(qwerty123)
...	...

Password Hashing

- Instead of user password, store $H(\text{password})$
- When user enters password, compute its hash and compare with entry in password file
 - System does not store actual passwords!
 - System itself can't easily go from hash to password
 - Which would be possible if the passwords were encrypted
- Hash function H must have some properties:
 - **One-way**: given $H(\text{password})$, hard to find password
 - No known algorithm better than brute forcing
 - **“Slow” to compute**

But there is a problem

Passwords are not truly random

- With 52 upper- and lower-case letters, 10 digits and 32 punctuation symbols, there are $94^8 \approx 6$ quadrillion possible 8-character passwords ($\sim 2^{52}$)
- BUT: Humans like to use dictionary words, human and pet names ≈ 1 million common passwords
- Passwords have skewed distributions
 - Top 5000 passwords cover 20% of users
 - Typically have 10-20 bits of entropy

Dictionary Attack

- **Dictionary attack** is possible because many passwords come from a small dictionary
 - Sophisticated password guessing tools are available
 - Take into account freq. of letters, password patterns, etc.



Rainbow Table
precompute a map of
password $\rightarrow$ Hash Values



- **Rainbow Table: Attacker can pre-compute $H(\text{word})$ for every word in the dictionary – this only needs to be done once!**
 - This is an offline attack
 - Once password file is obtained, cracking is instantaneous

How to protect against dictionary attacks?



Salt the hash
(stored as plaintext alongside password)

User	Password		User	Salt	Password
alice	Hash(password123)	Salt →	alice	EW3n	Hash(EW3n,password123)
bob	Hash(qwerty123)		bob	fn5D	Hash(fn5D,qwerty123)
...	...		...	...	...

- Salt is random, users with the same password have different entries in the password file
- Offline dictionary attack becomes much harder

Salting

- Salt is random data added to a password before hashing. Each user should have a unique salt. It ensures that even identical passwords create unique hashes.
- Salts are stored alongside the hashes, usually in plain text.
- This mostly prevents attackers from using precomputed tables like rainbow tables and makes cracking multiple passwords much harder and slower.

Advantages of Salting

- Without salt, attacker can pre-compute hashes of all dictionary words once for all password entries
 - Same hash function on all UNIX machines
 - Identical passwords hash to identical values; one table of hash values can be used for all password files
- With salt, attacker must compute hashes of all dictionary words once for each password entry
 - With 12-bit random salt, same password can hash to 2^{12} different hash values
 - Attacker must try all dictionary words **for each salt value** in the password file
- Pepper: Secret salt (not stored in password file)
 - Recommended by NIST as of 2017

Example Question

Mallory obtained a dictionary containing 100,000 commonly used passwords.

- Calculating the hash code of one password takes 0.1 seconds.
- Finding the corresponding password with the hash code takes 10^{-6} seconds.

Mallory can perform all possible calculations before attempting to attack the server.

Assume that there are 25,000 accounts on the server, and they all use passwords within the dictionary. The hash codes of their passwords are stored on the server.

- 1) How long does it take to calculate the hash codes of all the passwords in the dictionary?
- 2) Mallory break the server security and obtained the hash codes of all the passwords. How long does it take to obtain all the passwords?

1) $100000 * 0.1 = 10000$ seconds (less than 3 hours)

2) $25000 * 10^{-6} = 0.25$ seconds

Example Question (Continued)

Now the hash codes of (salt||password) are stored on the server. The salt consists of 30 randomly generated bits and is stored as plaintext alongside the hash codes.

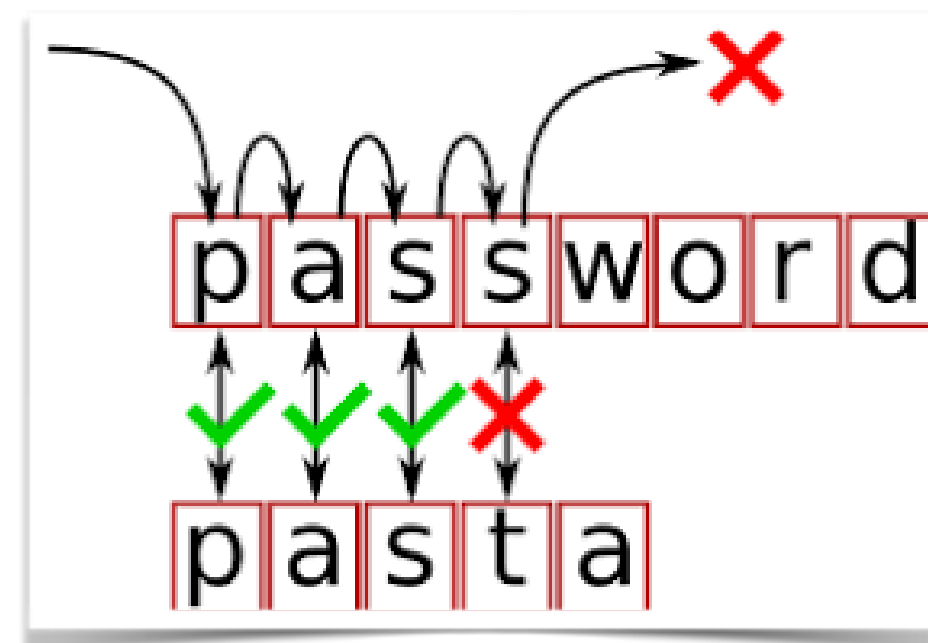
- 1) Considering the 30-bit salt, how long does it take to precompute the hash codes for one password across all salt values? Use the approximation: $10^3 = 2^{10}$
- 2) Mallory break the server security and obtained all the hash codes and corresponding salts. How long does it take to obtain the password for one account?

1) $2^{30} * 0.1 = 10^9 * 0.1 = 10^8$ seconds (more than 3 years)

2) $100000 * 0.1 + 10^{-6} = 10000$ seconds

Other Password Security Risks

- Keystroke loggers
 - Hardware
 - Software (spyware)
- Shoulder surfing
- Social engineering
- Same password at multiple sites
- Broken implementations
 - TENEX timing attack



TENEX Timing Attacks

- 1970s: TENEX operating system compares user-supplied string against secret password one character at a time, stopping at first difference:
 - AAAAAA vs. SECRET: stop at 1.
 - SAAAAA vs. SECRET: stop at 2.
 - SEAAAA vs. SECRET: stop at 3.
- Attacker sees comparison time, deduces position of difference.
- A few hundred tries reveal secret password.

```
for (i = 0; i < 16; ++i)
    if (x[i] != y[i])
        return 0;
return 1;
```

```
int result = 0;
for (i = 0; i < 16; ++i)
    result |= x[i] ^ y[i];
return result == 0;
```

Notice that the language makes the wrong thing simple and the right thing complex.

Other Issues

- Usability
 - Hard-to-remember passwords?
 - Carry a physical object all the time?
- Denial of service
 - Attacker tries to authenticate as you, account locked after three failures

Default Passwords

- Examples from Mitnick's "Art of Intrusion"
 - U.S. District Courthouse server: "public" / "public"
 - NY Times employee database: pwd = last 4 SSN digits
- Also
 - "Your default password is the last 6 digits of your ID"

Weak Passwords

- RockYou hack (2009)



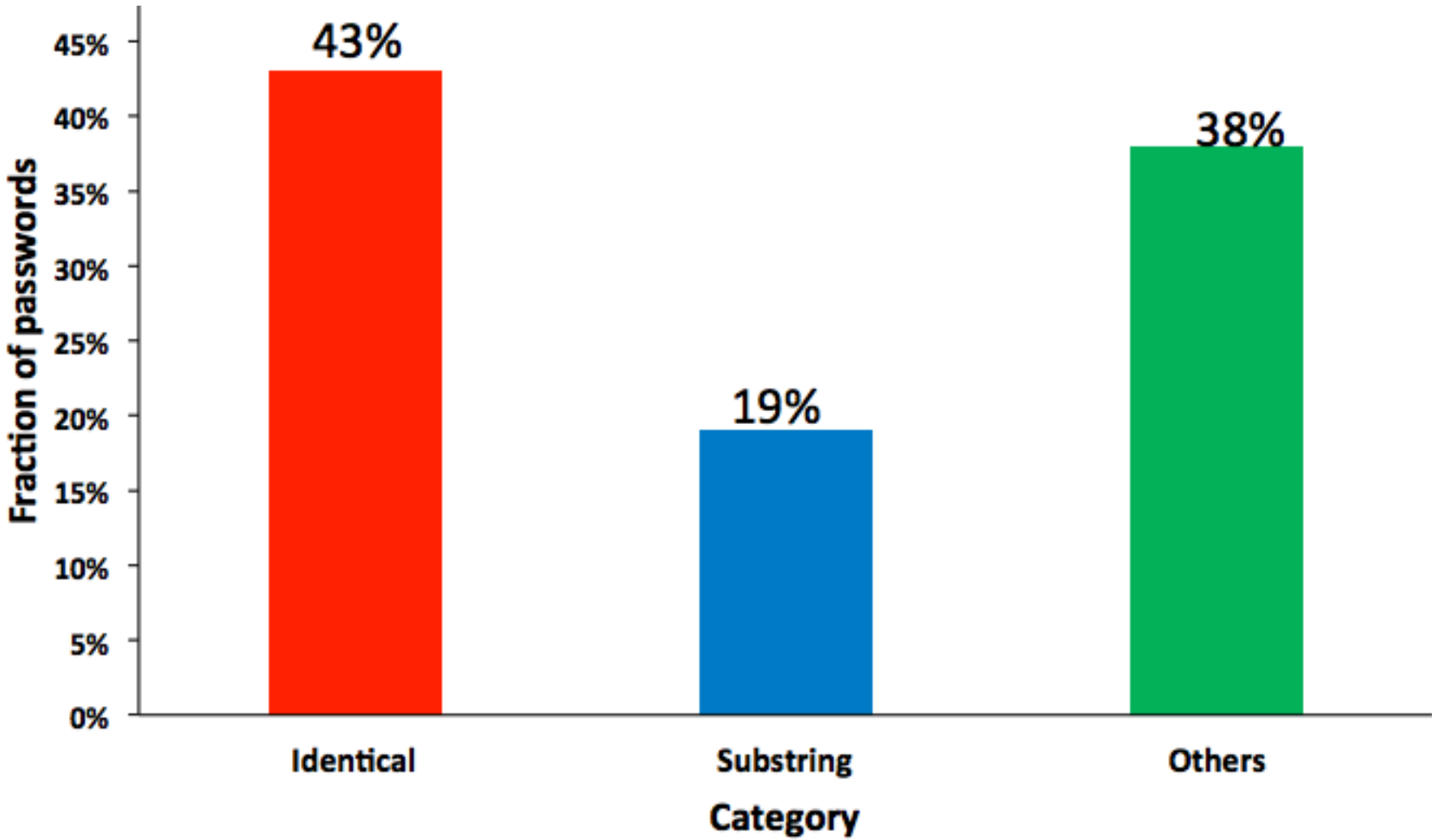
Password Popularity – Top 20

Rank	Password	Number of Users with Password (absolute)
1	123456	290731
2	12345	79078
3	123456789	76790
4	Password	61958
5	iloveyou	51622
6	princess	35231
7	rockyou	22588
8	1234567	21726
9	12345678	20553
10	abc123	17542

Rank	Password	Number of Users with Password (absolute)
11	Nicole	17168
12	Daniel	16409
13	babygirl	16094
14	monkey	15294
15	Jessica	15162
16	Lovely	14950
17	michael	14898
18	Ashley	14329
19	654321	13984
20	Qwerty	13856

Password Reuse

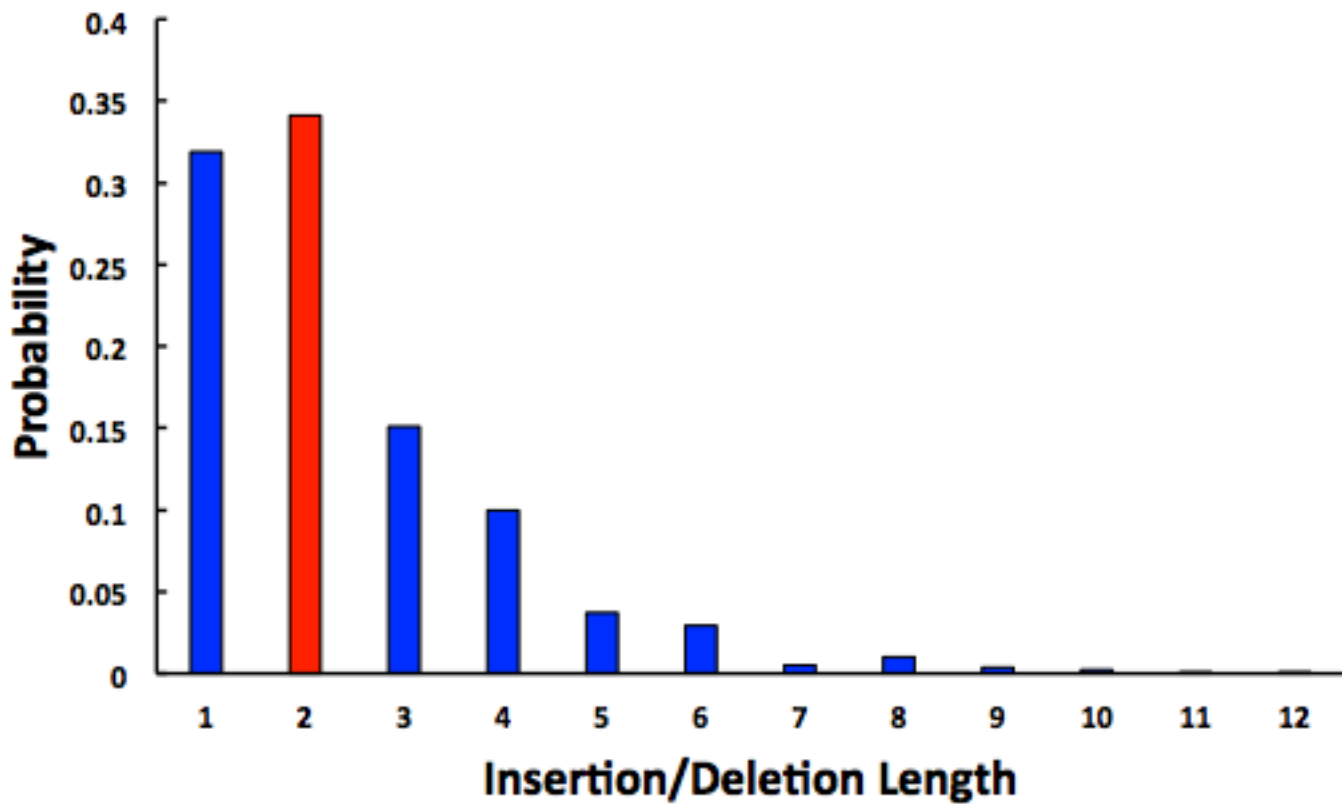
Email ID	Passwords	
116	iloveyou	iloveyou
117	loving	loving1
118	naughty	NAUGHTY
119	password	pa55wOrd
120	logout0616	logout
121	butcher05	Butcher05
122	joey1992	joey92
123	123456	12345678
124	gzwz0204	0204gzwz
125	mike04	jade1979
126	lucky777	lucky7



Insertion/Deletion Location

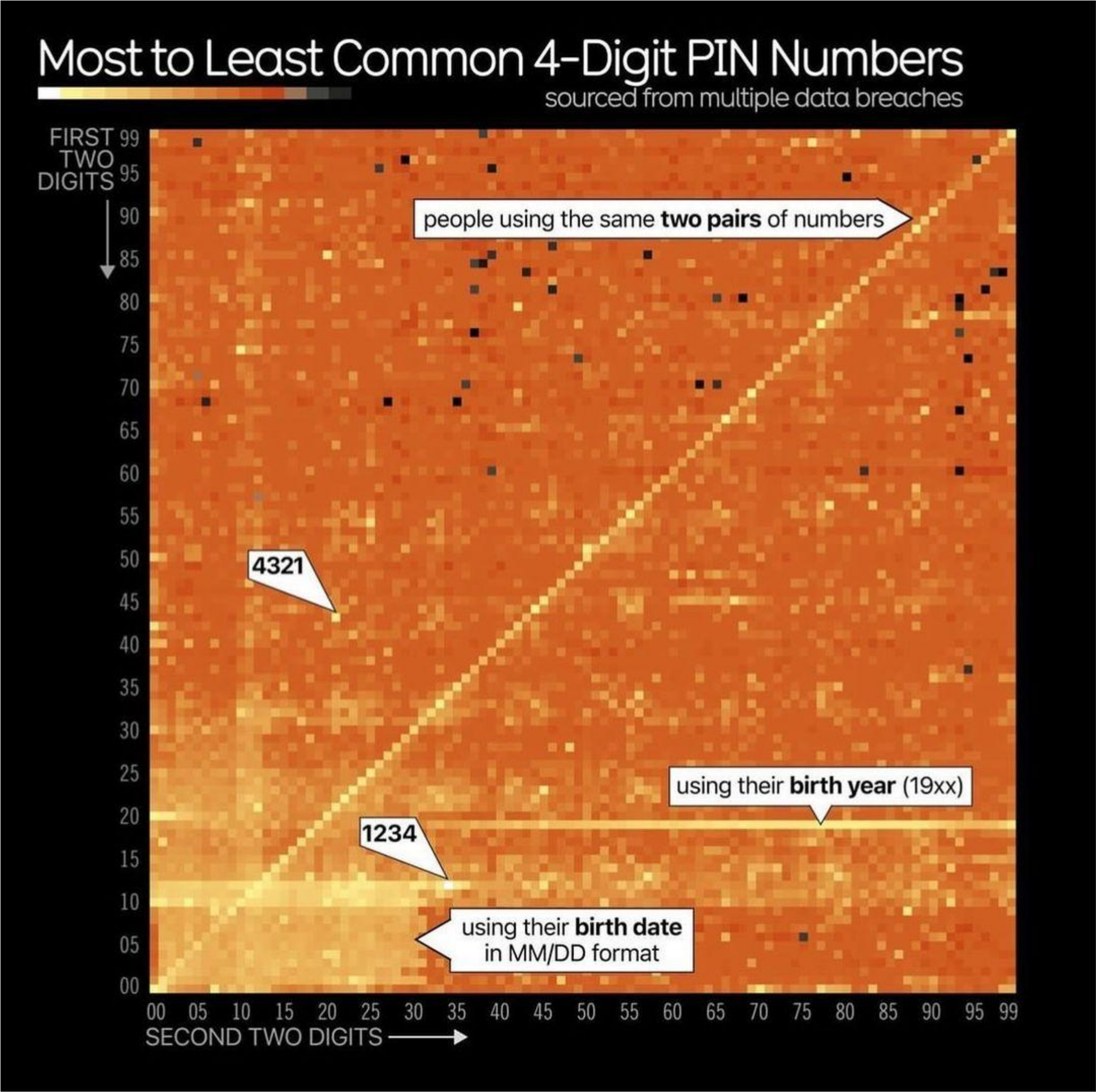
Location	Percentage
At start	10%
At end	88%
At both ends	2%

Distribution of Insertion/Deletion Length



PINs

	PIN	Freq
#9980	8557	0.001191%
#9981	9047	0.001161%
#9982	8438	0.001161%
#9983	0439	0.001161%
#9984	9539	0.001161%
#9985	8196	0.001131%
#9986	7063	0.001131%
#9987	6093	0.001131%
#9988	6827	0.001101%
#9989	7394	0.001101%
#9990	0859	0.001072%
#9991	8957	0.001042%
#9992	9480	0.001042%
#9993	6793	0.001012%
#9994	8398	0.000982%
#9995	0738	0.000982%
#9996	7637	0.000953%
#9997	6835	0.000953%
#9998	9629	0.000953%
#9999	8093	0.000893%



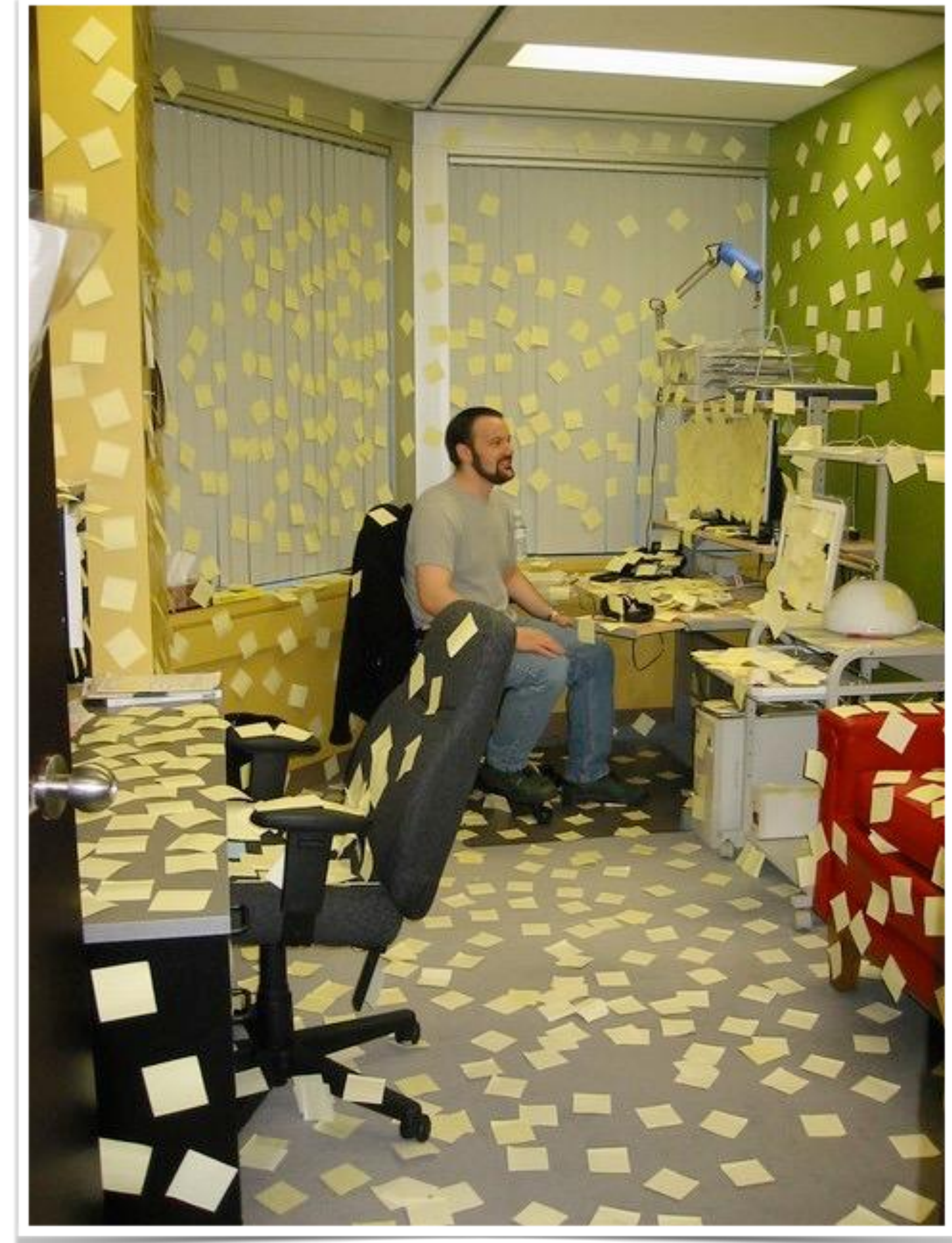
	PIN	Freq
#1	1234	10.713%
#2	1111	6.016%
#3	0000	1.881%
#4	1212	1.197%
#5	7777	0.745%
#6	1004	0.616%
#7	2000	0.613%
#8	4444	0.526%
#9	2222	0.516%
#10	6969	0.512%
#11	9999	0.451%
#12	3333	0.419%
#13	5555	0.395%
#14	6666	0.391%
#15	1122	0.366%
#16	1313	0.304%
#17	8888	0.303%
#18	4321	0.293%
#19	2001	0.290%
#20	1010	0.285%

Password Recovery

- Password Strength =
Min(Password Strength, Recovery Question Strengths)
- Password Hint
- Secret Questions
 - Low Entropy
 - Social Media
 - User selected ones are especially bad

Password Policies

- Old recommendation:
 - 7 or 8 characters, at least 3 out of {digits, upper-case, lower-case, non-alphanumeric}, no dictionary words, change every 4 months, password may not be similar to previous 12 passwords...
- But... results in frustrated users and less security
 - Burdens of devising, learning, forgetting passwords
 - Users construct passwords insecurely, write them down
 - Can't use their favorite password construction techniques (small changes to old passwords, etc.)
 - Heavy password re-use across systems



Current NIST Standard

SP 800-63-3

- **Requirements**

- Set an 8-character minimum length.
- No periodic password change. Change passwords only if there is evidence of compromise.
- Screen new passwords against a list of known compromised/common used passwords.
- Skip password hints and knowledge-based security questions.
- Limit the number of failed authentication attempts.

- **Recommendations**

- Set the maximum password length to at least 64 characters.
- Skip character composition rules as they are an unnecessary burden for end-users.
- Allow copy and paste functionality in password fields to facilitate the use of password managers.
- Allow the use of all printable ASCII characters as well as all UNICODE characters (including emojis).

Improving(?) Passwords

- Two-factor authentication
 - Leverage phone (or other device) for authentication
- Password managers
 - Examples: LastPass, KeePass, built into browsers
 - Can have security vulnerabilities...
- Graphical passwords
 - Goal: easier to remember? no need to write down?
- Add biometrics
 - For example, keystroke dynamics or voiceprint, face recognition

Multi-Factor Authentication

SMS



2-Step Verification

This extra step shows it's really you trying to sign in

2-Step Verification

A text message with a 6-digit verification code was just sent to (***). Enter the code

Enter the code

G- |

☒ Don't ask again on this computer



Verify it's you

There's something unusual about how you're signing in.
To show that it's really you, complete the task below.



Confirm the phone number you provided in your security settings: (***). Enter phone number

Done

[Try another way to sign in](#)



Verify it's you

There's something unusual about how you're signing in.
To show that it's really you, complete the task below.



Enter a verification code

A text message with a verification code was just sent to (***). Enter the 6-digit code

Done

☒ Don't ask again on this computer

Multi-Factor Authentication

Authenticator App



Set up Authenticator

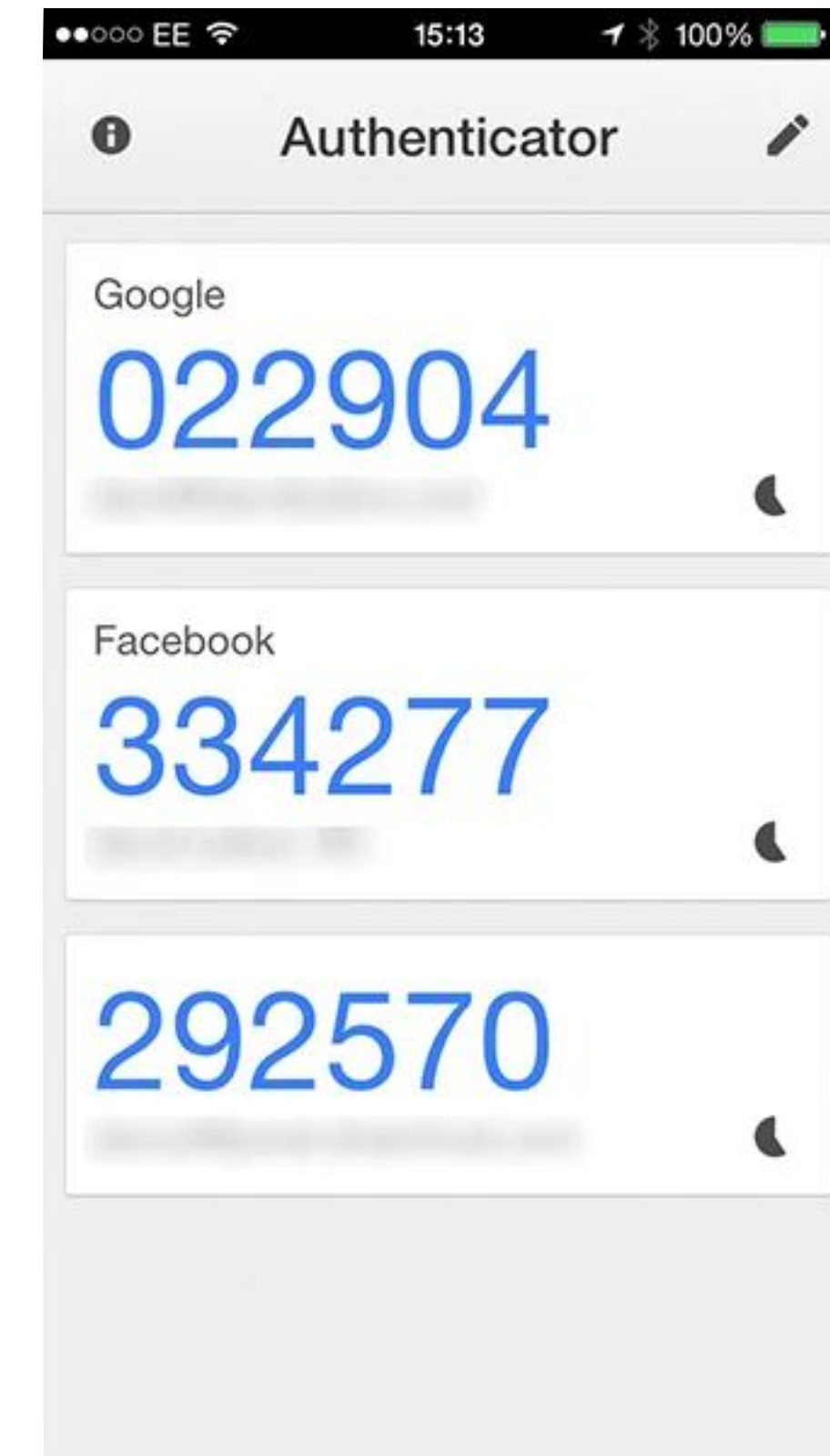
- Get the Authenticator App from the [Play Store](#).
- In the App select **Set up account**.
- Choose **Scan a barcode**.



[CAN'T SCAN IT?](#)

[CANCEL](#)

[NEXT](#)



Multi-Factor Authentication

FIDO + Hardware Two Factors



Password Managers

- **One secure password instead of 100 insecure ones**
- **Single Point of failure**
 - Server compromise
 - “Zero-knowledge”
 - Password leakage
 - Two-factor
 - New device/location verification
- **Challenges still remain**
 - Usability

LastPass...



bitwarden

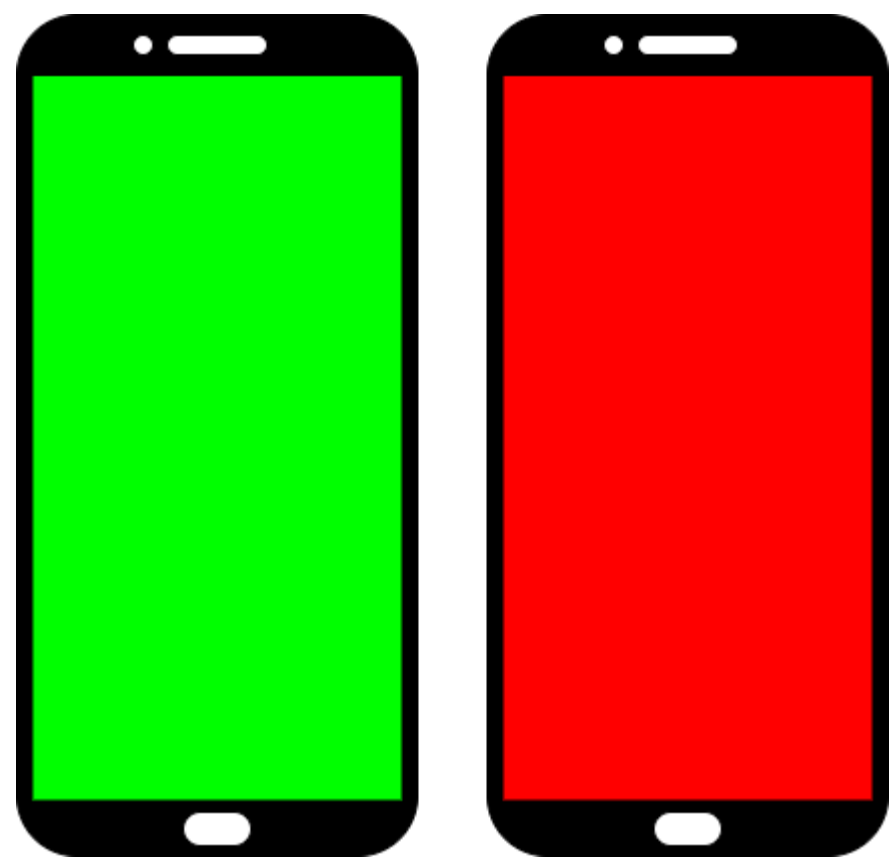
1Password

What About Biometrics?

- Authentication: **What you are**
- Unique identifying characteristics to authenticate user or create credentials
 - **Biological and physiological:** Fingerprints, iris scan
 - **Behaviors characteristics - how perform actions:** Handwriting, typing, gait
- Advantages:
 - Nothing to remember
 - Passive
 - Can't share (generally)
 - With perfect accuracy, could be fairly unique

Issues with Biometrics

- Private, but not secret
 - Maybe encoded on the back of an ID card?
 - Maybe encoded on your glass, door handle, ...
 - Sharing between multiple systems?
- Revocation is difficult (impossible?)
 - Sorry, your iris has been compromised, please create a new one...
- Physically identifying
 - Soda machine to cross-reference fingerprint with DMV?
- Birthday paradox
 - With false accept rate of 1 in a million, probability of false match is above 50% with only 1609 samples



Issues with Biometrics: WeChat Face Recognition

Private, but not secret

- (Somewhat) Addressed
- Flashing lights means that a picture of your face will not pass authentication
- Revocation is difficult (impossible?)
 - Not addressed
 - You need to contact other authorities
- Physically identifying
 - Not addressed
 - Policy related, not determined by the method of face recognition
- Birthday paradox
 - Addressed
 - WeChat uses facial recognition for **verification** (is this the account owner?) rather than **identification** (who is this person?)